NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 1

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total marks: 10 x 1 = 10**

QUESTION 1:

Which of the following belong to the CIA Triad in information security?

a. Confidentiality
b. Authentication
c. Availability
d. Accountability
e. Integrity
f. Authorization

Correct Answer: a, c, e

Detail Solution: The CIA Triad consists of Confidentiality, Integrity, and Availability. Authentication, non-repudiation, accountability, and authorization are important security concepts but are not part of the core CIA Triad.
Thus, the correct options are (a), (c), and (e).

QUESTION 2:

Which of the following penetration testing models provides the tester with no prior information about the target network?

a. White box model
b. Black box model
c. Gray box model
d. Blue box model

Correct Answer: b

Detail Solution: In the white box model, the tester has complete information about the network. In the black box model, the tester has no information about the network. The grey box model provides partial information. There is no standard model called the blue box model. Thus, the correct option is (b).

QUESTION 3:

Which of the following statement(s) is/are true for packet-switched networks?

a. Bandwidth is dedicated for the entire duration of a session.
b. Multiple connections can share the same communication link.
c. Delay is always constant regardless of network load.
d. It requires end-to-end circuit setup before data transfer.
e. Data is divided into smaller packets before transmission.
f. It guarantees zero packet loss under all conditions.

Correct Answer: b, e

Detail Solution: In packet switching, communication links may be shared by more than one connection, and data is broken into smaller packets before transmission. Dedicated bandwidth and constant delay are characteristics of circuit switching. Packet switching does not require prior circuit setup, and it does not guarantee zero packet loss.
Thus, the correct options are (b) and (e).

QUESTION 4:

Which OSI layer is primarily responsible for framing, MAC addressing, and error detection over a physical link?

a. Physical layer
b. Data link layer
c. Network layer
d. Transport layer
e. Session layer

Correct Answer: b

Detail Solution: The data link layer organizes bits into frames, provides MAC addressing, and performs error detection over a point-to-point or shared link. The physical layer deals with raw bit transmission, and the network layer handles routing and logical addressing.

Thus, the correct option is (b).

QUESTION 5:

A 1500-byte packet is sent over a 100 Kbps point-to-point link whose propagation delay is 8 msec. The packet will reach the destination after _____ msec. (Assume 1K = 1000)

Correct Answer: 120 to 130

Detail Solution: Transmission rate = 100,000 bits per second.
1500 bytes = 12,000 bits.
Transmission time = 12,000 / 100,000 = 0.12 sec = 120 msec.
Total time = 120 + 8 = 128 msec.

QUESTION 6:

What is the primary purpose of an IP address in a network?

a. It identifies the physical hardware manufacturer of a device.
b. It uniquely identifies a host or interface on a network.
c. It specifies the number of open ports on a system.
d. It determines the encryption algorithm used by a host.

Correct Answer: b

Detail Solution: An IP address is a logical address that uniquely identifies a host or a specific network interface, enabling routing of packets to the correct destination. It is unrelated to hardware manufacturer identification, open ports, or encryption.
Thus, the correct option is (b).

QUESTION 7:

_____ is the minimum size (in bytes) of a TCP header without options.

Correct Answer: 20

Detail Solution: The minimum size of a TCP header is 20 bytes when no options are used. Additional options can increase this size up to 60 bytes.

Thus, the correct answer is 20.

QUESTION 8:

Which IP header field is decremented at every router hop and is primarily used to prevent packets from looping indefinitely in a network?

a. Header checksum
b. Fragment offset
c. Time to Live (TTL)
d. HLEN
e. Identification

Correct Answer: c

Detail Solution: The Time to Live (TTL) field is decremented by 1 at every router hop. When it reaches 0, the packet is discarded, preventing it from looping indefinitely in the network. Header checksum is used for error detection, fragment offset and identification are used for reassembly, and HLEN indicates header length.

Thus, the correct option is (c).

QUESTION 9:

If the IP header is 224 bits long, what will be the value (in decimal) of the HLEN field?

Correct Answer: 7

Detail Solution: HLEN represents the header length in multiples of 32 bits (4 bytes).

Thus, 224 bits = 7 x 32 bits. Hence HLEN = 7.

Thus the correct answer is 7.

QUESTION 10:

_____bits are used to represent a MAC address.

Correct Answer: 48

Detail Solution: A MAC address (data link layer / hardware address) is 48 bits long, typically represented as 12 hexadecimal digits.
Thus, the correct answer is 48.

**********END*******

NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 2

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total marks: 10 x 1 = 10**

QUESTION 1:

An IP packet arrives with the first eight bits as 0100 0101. How many bytes are there in the OPTIONS field?

Correct Answer: 0

Detail Solution: First four bits (0100) = version 4. Next four bits (0101 = 5) = header length. Header length = 5 x 4 = 20 bytes, which is the minimum IP header size with no options. Thus the OPTIONS field size = 20 - 20 = 0 bytes.

QUESTION 2:

Which of the following is/are true for TCP header flag bits?

a. SYN=1, ACK=0 indicates a connection request.
b. SYN=1, ACK=1 indicates connection confirmation.
c. FIN flag is used to reject a connection.
d. RST flag is used to gracefully terminate a connection.
e. URG flag indicates urgent data in the segment.

Correct Answer: a, b, e

Detail Solution: SYN=1, ACK=0 is a connection request; SYN=1, ACK=1 is connection confirmation; URG flag indicates urgent data. FIN is used for graceful connection termination (not rejection), and RST is used to abruptly reset/reject a connection (not graceful termination). Thus, the correct options are (a), (b), and (e).

QUESTION 3:

Which of the following represents a valid broadcast address for its respective subnet (as specified)?

a. 10.255.255.255 for network 10.0.0.0/8
b. 10.20.0.0 for network 10.20.0.0/16
c. 192.168.5.255 for network 192.168.5.0/24
d. 172.16.255.0 for network 172.16.0.0/16
e. 192.168.5.0 for network 192.168.5.0/24

Correct Answer: a, c

Detail Solution: For 10.0.0.0/8, the host portion is 24 bits, so broadcast address = 10.255.255.255 (all host bits set to 1). For 192.168.5.0/24, the host portion is 8 bits, so broadcast address = 192.168.5.255. Option (b) is the network address, not broadcast. Option (d) is incorrect since for /16, broadcast address should be 172.16.255.255, not 172.16.255.0. Option (e) is the network address, not a broadcast address.
Thus, the correct options are (a) and (c).

QUESTION 4:

An IP packet arrives at the final destination with D flag = 0, M flag = 0, and offset = 5. Which of the following is true?

a. The packet has not been fragmented.
b. The packet is the first fragment.
c. The packet is the last fragment of a fragmented packet.
d. The packet will be dropped due to invalid flags

Correct Answer: c

Detail Solution: M = 0 indicates no more fragments follow, meaning this is the last fragment. A non-zero offset (5) confirms fragmentation has occurred, ruling out option (a). Hence, it is the last fragment of a fragmented packet.
Thus, the correct option is (c).

QUESTION 5:

Which of the following IP address ranges are reserved for private use?

a. 10.0.0.0 to 10.255.255.255
b. 100.64.0.0 to 100.127.255.255
c. 172.16.0.0 to 172.31.255.255
d. 192.168.0.0 to 192.168.255.255
e. 169.254.0.0 to 169.254.255.255
f. 224.0.0.0 to 239.255.255.255

Correct Answer: a, c, d

Detail Solution: The private IP ranges as per RFC 1918 are 10.0.0.0/8, 172.16.0.0/12, and 192.168.0.0/16. 169.254.x.x is reserved for link-local addressing (APIPA), 100.64 to 100.127 is for CGNET, and 224.0.0.0 to 239.255.255.255 is the Class D multicast range.
Thus, the correct options are (a), (c), and (d).

QUESTION 6:

Which of the following well-known port number(s) is/are correctly matched with their corresponding service?

a. HTTP – 80
b. FTP – 21
c. SSH – 25
d. DNS – 23
e. Telnet – 53
f. SMTP – 22

Correct Answer: a, b

Detail Solution: HTTP uses port 80, FTP uses port 21, DNS uses port 53, and Telnet uses port 23, SSH uses port 22, and SMTP uses port 25.

Thus the correct options are (a) and (b).

QUESTION 7:

What is the subnet mask corresponding to CIDR notation /26?

a. 255.255.255.0
b. 255.255.255.128
c. 255.255.255.192
d. 255.255.255.224
e. 255.255.255.240

Correct Answer: c

Detail Solution: /26 means 26 network bits, leaving 6 host bits. The last octet becomes 11000000 = 192. So the subnet mask is 255.255.255.192.

Thus the correct option is (c).

QUESTION 8:

Which of the following statement(s) is/are true about IPv4 fragmentation and the "Don't Fragment" (DF) bit?

a. If DF = 1 and packet size exceeds MTU, the packet is dropped and an error is generated.
b. If DF = 1, the router fragments the packet regardless of size.
c. If DF = 0, fragmentation is allowed if necessary.
d. DF bit is part of the Fragment Offset field.
e. DF = 1 guarantees the packet will always reach its destination.

Correct Answer: a, c

Detail Solution: If DF = 1 and the packet exceeds the outgoing MTU, the router drops the packet and typically sends an ICMP "Fragmentation Needed" error. If DF = 0, fragmentation is permitted when required. DF is part of the Flags field, not Fragment Offset, and setting DF=1 does not guarantee delivery.

Thus the correct options are (a) and (c).

QUESTION 9:

An IP packet has HLEN = 12 and TOTAL LENGTH = 900 bytes. The number of data bytes in the packet will be _____.

Correct Answer: 852

Detail Solution: HLEN = 12 means header size = 12 x 4 = 48 bytes. Data bytes = 900 - 48 = 852 bytes.

Thus the correct answer is 852.

QUESTION 10:

_____ is the size (in bytes) of a UDP header.

Correct Answer: 8

Detail Solution: The UDP header has 4 fields (source port, destination port, length, checksum), each of 2 bytes, totaling 8 bytes.
Thus, the correct answer is 8.

**********END*******

NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 3

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

Which of the following statement(s) is/are true regarding connectionless routing used by the IP protocol?

a. Each packet is treated as an independent unit for routing decisions.
b. A fixed path is established before any packet is transmitted.
c. Different packets between the same source and destination may follow different paths.
d. IP protocol uses connection-oriented routing.

Correct Answer: a, c

Detailed Solution: IP uses connectionless routing, where each packet is treated independently and may follow a different path even between the same source-destination pair. IP does not establish a fixed path beforehand (that is connection-oriented behavior).

Thus, the correct options are (a) and (c).

QUESTION 2:

Which of the following statement(s) is/are **false** regarding direct and indirect packet delivery?

a. Direct delivery occurs when the destination host and deliverer are on the same physical network.
b. Indirect delivery occurs when the destination host is not on the same network as the deliverer.
c. In direct delivery, packets always pass through at least one router.
d. In indirect delivery, the packet is routed hop by hop until it reaches a router on the destination's network.
e. Direct delivery can occur between the last router and the destination host.

Correct Answer: c

Detailed Solution: Direct delivery occurs when source and destination share the same physical network, or between the last router and the destination host — hence it does NOT always require passing through a router, making (c) false. All other statements correctly describe direct/indirect delivery.
Thus, the correct (false) option is (c).

QUESTION 3:

Which routing table flag indicates that a route is specific to a single host rather than an entire network?

a. U
b. G
c. H
d. D
e. M

Correct Answer: c

Detailed Solution: The H flag in a routing table entry indicates that the route is host-specific (a route to a single host), as opposed to a route to an entire network.
Thus the correct option is (c).

QUESTION 4:

In the OSPF routing protocol, which type of packet is used to determine whether a neighboring router is active?

a. Link State Update
b. Link State Request
c. Hello packet
d. Link State Acknowledgement
e. TCP SYN packet

Correct Answer: c

Detailed Solution: OSPF uses "Hello" packets periodically exchanged between neighbouring routers to check whether a neighbour is alive/active. If Hello packets are not received within a timeout period, the neighbour is considered down.
Thus, the correct option is (c).

QUESTION 5:

Which type of address should be used when a packet needs to be delivered to every host within a specific network?

a. Unicast address
b. Broadcast address
c. Anycast address
d. None of these

Correct Answer: b

Detailed Solution: A broadcast address is used to deliver a packet to all hosts within a given network or subnetwork. Unicast targets a single specific host, and anycast targets the nearest of a group of hosts.

Thus, the correct option is (b).

QUESTION 6:

Which of the following statement(s) is/are **false** regarding routing protocols?

a. RIP uses distance vector routing and can suffer from the count-to-infinity problem.
b. OSPF is a link-state routing protocol.
c. BGP is used for routing within a single autonomous system.
d. OSPF uses Dijkstra's algorithm to compute shortest paths.
e. RIP is typically used for routing between different autonomous systems.

Correct Answer: c, e

Detailed Solution: BGP is an exterior routing protocol used for routing between different autonomous systems, not within a single AS, making (c) false. RIP is an interior protocol used within a single AS, not between different ASes, making (e) false. RIP's distance vector approach can indeed suffer from count-to-infinity, and OSPF is a link-state protocol using Dijkstra's algorithm - both correctly stated.

Thus, the correct (false) options are (c) and (e).

QUESTION 7:

What is the address used to represent the default route in a routing table (in IPv4)?

a. 127.0.0.1
b. 255.255.255.255
c. 0.0.0.0
d. 192.0.0.1
e. None of these

Correct Answer: c

Detailed Solution: The default route, also called the "gateway of last resort," is represented by the address 0.0.0.0 (with subnet mask 0.0.0.0, or /0 in CIDR), and is used for packets that don't match any other entry in the routing table.

Thus, the correct option is (c).

QUESTION 8:

Which of the following statement(s) is/are **false** regarding IPv6?

a. IPv6 supports address classes similar to IPv4 (Class A, B, C).
b. IPv6 addresses are typically represented in hexadecimal, separated by colons.
c. IPv6 eliminates the need for fragmentation by intermediate routers.
d. The base header size of IPv6 is variable, ranging from 20 to 60 bytes.

Correct Answer: a, d

Detailed Solution: IPv6 does not use classful addressing like IPv4 (no Class A/B/C), making (a) false. The IPv6 base header has a fixed size of 40 bytes (not variable 20-60 bytes, which describes IPv4), making (d) false. IPv6 addresses are indeed hexadecimal and colon-separated, fragmentation in IPv6 is done only by the source (not intermediate routers).

Thus, the correct (false) options are (a) and (d).

QUESTION 9:

In IPv6 base header _____ bits are used for Hop Limit?

Correct Answer: 8

Detailed Solution: The Hop Limit field in the IPv6 base header is 8 bits wide, serving a similar function to the TTL field in IPv4 - it is decremented at each hop, and the packet is discarded when it reaches 0.

Thus, the correct answer is 8.

QUESTION 10:

An organization is assigned 172.20.64.0/20 network block. _____ number of valid host addresses are available in this block.

Correct Answer: 4094

Detail Solution: A /20 prefix leaves 12 host bits, giving 2^12 = 4096 addresses. Subtracting the network address and broadcast address leaves 4094 usable host addresses.

**********END*******

NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 4

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

What is the primary purpose of a Hypervisor in a penetration testing lab setup?

a. It encrypts all network traffic between virtual machines.
b. It allows creation and management of multiple virtual machines on a single physical system.
c. It is a hack-proof security layer for the host OS.
d. It automatically patches vulnerabilities on guest machines.
e. None of these.

Correct Answer: b

Detailed Solution: A hypervisor (Virtual Machine Monitor) allows one physical host to create and run multiple virtual machines, sharing the host's resources such as CPU, memory, and storage. It has no role in encryption, security hardening, or automatic patching.
Thus, the correct option is (b).

QUESTION 2:

Which of the following information CANNOT typically be retrieved using a Whois lookup?

a. Domain registration details
b. Name servers
c. Registrant contact information
d. Historical snapshots of the website
e. Domain expiration date

Correct Answer: d

Detailed Solution: A Whois lookup provides registration details, name servers, contact information, and a domain's expiration date. Historical snapshots of a website are retrieved using services like Archive.org's Wayback Machine, not Whois.

Thus, the correct option is (d).

QUESTION 3:

How does host discovery using an ICMP Echo sweep work?

a. An ICMP type-8 request is sent, and an ICMP type-0 reply confirms the host is alive.
b. A TCP SYN packet is sent, and an ACK confirms the host is alive.
c. It broadcasts ARP requests to identify all hosts on the segment.
d. None of these.

Correct Answer: a

Detailed Solution: In ICMP Echo sweep, an ICMP Echo Request (type 8) is sent to the target; receiving an ICMP Echo Reply (type 0) indicates the host is alive. TCP SYN/ACK relates to TCP-based discovery, not ICMP.
Thus, the correct option is (a).

QUESTION 4:

Which NMAP option(s) can be used to perform a TCP-based host discovery sweep?

a. -PE
b. -PS
c. -PA
d. -PU
e. -PM

Correct Answer: b, c

Detailed Solution: -PS (TCP SYN ping) and -PA (TCP ACK ping) are used for TCP-based host discovery sweeps. -PE is used for ICMP Echo sweep, -PU is used for UDP sweep, and -PM is used for ICMP Netmask (non-echo) sweep.

Thus, the correct options are (b) and (c).

QUESTION 5:

During the TCP three-way handshake, what type of message does the client send first to initiate the connection?

a. ACK
b. SYN
c. SYN-ACK
d. RST
e. FIN

Correct Answer: b

Detailed Solution: The client initiates the TCP three-way handshake by sending a SYN packet indicating its intent to establish a connection and the initial sequence number.

Thus, the correct option is (b).

QUESTION 6:

In a TCP SYN (stealth) scan, which packet response(s) indicates that a port is open or closed, respectively?

a. SYN-ACK received indicates the port is open.
b. RST received indicates the port is closed.
c. ACK received indicates the port is open.
d. FIN received indicates the port is open.

Correct Answer: a, b

Detailed Solution: In a TCP SYN scan, receiving a SYN-ACK indicates the port is open, while receiving an RST indicates the port is closed. ACK and FIN packets are not used as indicators in SYN scan responses.

Thus, the correct options are (a) and (b).

QUESTION 7:

Which of the following statement(s) is/are **true** regarding the default networking mode (NAT) in Oracle VirtualBox?

a. It assigns a unique public IP address to each virtual machine.
b. It assigns the same private/virtual IP address to guest operating systems.
c. Virtual machines using this mode can access the internet.
d. It assigns the host system's IP address directly to guest machines.
e. Virtual machines using NAT mode are directly reachable from outside the host by default.

Correct Answer: b, c

Detail Solution: The default NAT networking mode in VirtualBox assigns a virtual/private IP address to guest machines, and it allows internet access from within the guest. It does not assign unique public IPs, does not share the host's own IP address, and guests are not directly reachable from outside by default (NAT hides them behind the host).

Thus, the correct options are (b) and (c).

QUESTION 8:

Which of the following NMAP option(s) can be used for OS and/or service version detection?

a. -sn
b. O
c. sV
d. -Pn
e. A

Correct Answer: b, c, e

Detailed Solution: -O performs OS detection, -sV performs service/version detection, and -A (aggressive scan) combines OS detection, version detection, script scanning, and traceroute. -sn only performs host discovery (skips port scan), and -Pn skips host discovery entirely, neither of which relates to OS/version detection.

Thus, the correct options are (b), (c), and (e).

QUESTION 9:

If ports 80 and 443 are found open on a target system, what can be reasonably inferred?

a. The target is very likely running SSH services.
b. The target is very likely hosting a website (HTTP/HTTPS).
c. The target is running a mail server.
d. The target is running a DNS resolver.
e. None of these.

Correct Answer: b

Detailed Solution: Ports 80 and 443 are the standard ports for HTTP and HTTPS, respectively, so their being open strongly suggests the target is hosting a website. SSH typically uses port 22, mail servers use ports like 25/110/143, and DNS uses port 53 — none of which are indicated here.
Thus, the correct option is (b).

QUESTION 10:

If the --reason option is used along with a SYN scan. Which of the following is/are correct if reason field shows “syn-ack”?

a. The port is open because NMAP received a SYN-ACK response from the target.
b. The port is closed, and no evidence is available.
c. The target sent an RST packet in response.
d. None of these.

Correct Answer: a

Detailed Solution: When --reason shows “syn-ack” for a port marked open, it means NMAP concluded the port is open specifically because it received a SYN-ACK packet from the target in response to its SYN probe, which is the expected behaviour for an open port in a SYN scan.

Thus, the correct option is (a).

**********END*******

NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 5

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

Which of the following NMAP option(s) can trigger execution of NMAP scripts?

a. -A
b. -sC
c. -Pn
d. --script=default
e. -sn

Correct Answer: a, b, d

Detailed Solution: -sC runs the default set of NSE scripts (equivalent to --script=default), and -A (aggressive scan) also enables script scanning along with OS/version detection and traceroute. -Pn only skips host discovery, and -sn only performs host discovery — neither triggers script execution.
Thus, the correct options are (a), (b), and (d).

QUESTION 2:

Which of the following tool(s)/software CANNOT be used for vulnerability scanning?

a. Nessus
b. Hydra
c. Nexpose
d. Crunch
e. NMAP

Correct Answer: b, d

Detailed Solution: Nessus, Nexpose, and NMAP (with vulnerability scripts) are used for scanning vulnerabilities. Hydra is a password-cracking/brute-force tool, and Crunch is a wordlist generator - neither performs vulnerability scanning.
Thus, the correct options are (b) and (d).

QUESTION 3:

Which of the following is NOT considered a common password cracking approach?

a. Dictionary attack
b. Brute-force attack
c. Rule-based attack
d. Packet sniffing
e. Shoulder surfing

Correct Answer: d

Detailed Solution: Dictionary, brute-force, rule-based attacks, and shoulder surfing are all recognized password cracking/acquisition approaches. Packet sniffing is a technique for capturing network traffic and is not itself a password cracking method (though captured data could later aid one).
Thus, the correct option is (d).

QUESTION 4:

Which protocol in TCP/IP is connectionless and does not provide reliability?

a. TCP
b. UDP
c. FTP
d. TELNET

Correct Answer: b

Detailed Solution: UDP sends datagrams without establishing a connection; thus, it is fast but unreliable. TCP, FTP and TELNET are connection-oriented, in which a connection is established prior to data transfer.

Thus, the correct option is (b).

QUESTION 5:

Which tool is primarily used to generate custom wordlists for use in dictionary-based password attacks?

a. Hydra
b. Nessus
c. Crunch
d. Wireshark
e. Hashcat

Correct Answer: c

Detailed Solution: Crunch is specifically used to generate custom wordlists based on rules such as character sets, length, and patterns. Hydra performs the actual brute-force/dictionary login attempts, Nessus is for vulnerability scanning, Wireshark captures packets, and Hashcat cracks password hashes rather than generating wordlists.

Thus, the correct option is (c).

QUESTION 6:

Which of the following statement(s) is/are **false** regarding malware?

a. All malware types are capable of self-replication.
b. Malware can grant partial or full control of a system to an attacker.
c. Malware can be delivered through file sharing or fake/pirated software.
d. Malware can modify, corrupt, or delete data on infected systems.
e. None of these.

Correct Answer: a

Detailed Solution: Not all malware self-replicates - for example, Trojans typically do not self-replicate, while viruses and worms do. Malware can indeed give attackers partial/full control, spread via file sharing or fake software, and modify or delete data.

Thus, the correct (false) option is (a).

QUESTION 7:

In a MAC flooding attack, what is the primary goal of overwhelming a switch's CAM table?

a. To crash the switch permanently.
b. To force the switch to behave like a hub, broadcasting traffic to all ports.
c. To increase the switch's available memory.
d. To disable the switch's power supply.
e. None of these.

Correct Answer: b

Detailed Solution: When a switch's CAM (Content Addressable Memory) table is flooded with fake MAC entries, the switch may fail to determine the correct outgoing port for legitimate traffic and start broadcasting frames out of all ports like a hub, enabling easier packet sniffing.

Thus, the correct option is (b).

QUESTION 8:

Which of the following NMAP script(s) is/are used specifically for identifying the operating system of an SMB-enabled target?

a. smb-os-discovery
b. smb-brute
c. http-os-brute
d. smb-enum-users
e. ssh-brute.

Correct Answer: a

Detailed Solution: The smb-os-discovery script is specifically designed to identify the operating system of a target via SMB. smb-brute performs credential brute-forcing, smb-enum-users performs user enumeration, ssh-brute cracks SSH credentials, and http-os-brute is not a valid/standard NMAP script.

Thus, the correct option is (a).

QUESTION 9:

An attacker is using hydra to perform a dictionary attack on an SSH service, testing a wordlist of 5000 passwords against 4 different usernames. The maximum number of logins attempts that could be made is _____.

Correct Answer: 20000

Detailed Solution: Total attempts = number of usernames x number of passwords = 4 x 5000 = 20,000 (assuming every password is tried against every username, worst case before a match is found).

Thus, the correct answer is 20000.

QUESTION 10:

If a symmetric-style brute-force password cracker needs to try all combinations of a 4-character password using only lowercase letters (26 possible characters per position), how many total password combinations are possible?

Correct Answer: 456976

Detail Solution: Total combinations = 26^4 = 26 x 26 x 26 x 26 = 456,976.
Thus, the correct answer is 456976.

**********END*******

Course Name: ETHICAL HACKING

Assignment- Week 6

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

Which of the following attack types involves an attacker pretending to be a legitimate entity to gain unauthorized access?

a. Replay attack
b. Masquerade attack
c. Modification attack
d. Denial of service attack
e. Traffic analysis

Correct Answer: b

Detailed Solution: In a masquerade attack, an attacker pretends to be a legitimate entity or user to gain unauthorized access to a system or resource. Replay involves capturing and resending a transaction, modification involves altering a message in transit, DoS prevents legitimate access, and traffic analysis is a passive attack analyzing communication patterns. Thus, the correct option is (b).

QUESTION 2:

Encrypt the plaintext “SECURE” using a substitution cipher where each letter is replaced by its k-th next letter, assuming alphabets wrap around (Z followed by A) and k = 3.

a. VHFXUH
b. VFEXRU
c. UHFXVH
d. VHFXRV
e. None of these.

Correct Answer: a

Detailed Solution: Shifting each letter by 3: S→V, E→H, C→F, U→X, R→U, E→H. This gives the ciphertext “VHFXUH”.
Thus, the correct option is (a).

QUESTION 3:

Consider a mono-alphabetic cipher with the key mapping: (A B C D E F G H I J K L M N O P Q R S T U V W X Y Z) mapped to (Q W E R T Y U I O P A S D F G H J K L Z X C V B N M). What will be the encrypted form of the message “CODE”?

a. EGRT
b. EGDT
c. EODT
d. EGDR
e. None of these

Correct Answer: a

Detailed Solution: Using the given mapping: C→E, O→G, D→R, E→T. Hence, "CODE" encrypts to “EGRT”.
Thus, the correct option is (a).

QUESTION 4:

Which of the following statement(s) is/are **false** regarding hashing algorithms used for message integrity?

a. A good hash function should be resistant to collisions.
b. The same input will always produce the same hash output.
c. A hash function can be reversed to retrieve the original message.
d. Even a small change in input should produce a significantly different hash output.

Correct Answer: c

Detailed Solution: A good cryptographic hash function is collision-resistant, deterministic (the same input gives the same output), and exhibits the avalanche effect (small input changes drastically alter the output). Hash functions are one-way functions and cannot be reversed to retrieve the original input.

Thus, the correct (false) option is (c).

QUESTION 5:

Decrypt the ciphertext "KHOOR" which was encrypted using a substitution cipher with a shift of k = 3 (each letter replaced by its k-th next letter during encryption, the alphabets wrap around).

a. HELLO
b. WORLD
c. HELPS
d. HFLLO
e. None of these

Correct Answer: a

Detailed Solution: To decrypt, shift each letter back by 3: K→H, H→E, O→L, O→L, R→O. This gives "HELLO".

Thus, the correct option is (a).

QUESTION 6:

A DoS attack that makes a system or service inaccessible to legitimate users falls under which category of security attack?

a. Interruption
b. Interception
c. Modification
d. Fabrication
e. Replay

Correct Answer: a

Detailed Solution: A Denial-of-Service attack prevents legitimate users from accessing a system/service, which is classified as an interruption attack - an attack on availability.

Thus, the correct option is (a).

QUESTION 7:

For encryption using public-key cryptography, if sender A wants to send a confidential message to receiver B, which key is used to encrypt the message?

a. A's private key
b. A's public key
c. B's public key
d. B's private key

Correct Answer: c

Detailed Solution: In public-key cryptography, the sender encrypts the message using the receiver's public key, so that only the receiver can decrypt it using their corresponding private key.

Thus, the correct option is (c).

QUESTION 8:

_____ is the block size (in bits) used for plaintext blocks in the Data Encryption Standard (DES) algorithm.

Correct Answer: 64

Detailed Solution: DES processes plaintext in fixed 64-bit blocks, using a 56-bit key (with 8 additional parity bits, making the stored key 64 bits, though only 56 bits are effectively used for encryption).

Thus, the correct answer is 64.

QUESTION 9:

150 parties want to exchange messages securely using a public key encryption technique like RSA. How many distinct key values will be required?

Correct Answer: 300

Detailed Solution: In asymmetric (public-key) encryption, each party holds two keys (public and private). For N parties, total keys = 2N. For N = 150, 2 x 150 = 300.

Thus, the correct answer is 300.

QUESTION 10:

40 parties want to exchange messages securely using a symmetric key encryption algorithm. How many distinct keys will be required?

Correct Answer: 780

Detailed Solution: In symmetric encryption, every pair of communicating parties needs a separate key. For N parties, the number of keys = NC2 = N(N-1)/2. For N = 40, 40 x 39 / 2 = 780.
Thus, the correct answer is 780.

**********END*******

NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 7

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

A message M is fed to a hash function to generate hash value H = HASH(M). Which of the following statement(s) is/are **true**?

a. The number of bits in H is typically much smaller than the number of bits in M.
b. The number of bits in H and M are always exactly equal.
c. Hashing produces a fixed-length output regardless of input size.
d. The output length of a hash function grows proportionally with the input length.

Correct Answer: a, c

Detailed Solution: A hash function compresses an arbitrarily large input into a small, fixed-length output, regardless of input size. In hashing output length does not grow with input length.
Thus, the correct options are (a) and (c).

QUESTION 2:

Which of the following statement(s) is/are **true**?

a. The block size of DES is 64 bits.
b. The key size of DES is 128 bits.
c. The hash digest size of MD5 is 128 bits.
d. SHA-256 produces a 512-bit digest.
e. Triple DES uses a fixed 512-bit key.

Correct Answer: a, c

Detailed Solution: DES uses a 64-bit block size (with a 56-bit key, not 128 bits). MD5 produces a 128-bit digest, SHA-256 produces a 256-bit digest (not 512), and Triple DES's effective key length is up to 168 bits, not 512.

Thus, the correct options are (a) and (c).

QUESTION 3:

Which of the following statement(s) is/are **true** regarding SSL/TLS protocols?

a. HTTPS relies on SSL/TLS to secure HTTP communication.
b. SSL/TLS guarantees faster data transmission compared to plain HTTP.
c. TLS operates at the physical layer of the network stack.
d. The SSL Record Protocol guarantees non-repudiation of the sender.

Correct Answer: a

Detailed Solution: SSL/TLS (and HTTPS, built on it) operate above the IP layer, and the SSL Record Protocol handles data encryption. SSL/TLS adds cryptographic overhead rather than guaranteeing faster transmission; it does not operate at the physical layer, and the Record protocol does not provide non-repudiation.

Thus, the correct option is (a).

QUESTION 4:

Which of the following statement(s) is/are **true** regarding collision resistance in hash functions?

a. It is a weaker requirement than second preimage resistance.
b. It should be computationally difficult to find any two distinct messages producing the same hash.
c. Collision resistance guarantees encryption confidentiality.
d. Collision resistance is trivial to achieve for any hash function design.
e. Collision resistance applies only to keyed hash functions (MACs).

Correct Answer: b

Detailed Solution: Collision resistance requires that finding any two distinct messages with the same hash is computationally infeasible, generally a stronger (or equally strong) requirement than second preimage resistance. Collision resistance is unrelated to confidentiality, is not trivial to achieve, and applies to hash functions generally, not just keyed ones.

Thus, the correct option is (b).

QUESTION 5:

Which of the following statement(s) is/are **true** regarding digital signature verification?

a. The verifier uses the signer's public key to verify a signature.
b. The verifier uses the signer's private key to verify a signature.
c. Successful verification confirms the message has not been altered and was signed by the claimed signer.
d. Verification requires the signer to be online and actively participating.

Correct Answer: a, c

Detailed Solution: Verification uses the signer's public key, which anyone can access, allowing confirmation of both message integrity and signer identity. It does not require the signer's active participation.
Thus, the correct options are (a) and (c).

QUESTION 6:

Which property of digital signatures ensures that the original signer cannot later deny having signed a message?

a. Confidentiality
b. Integrity
c. Non-repudiation
d. Availability
e. Authentication

Correct Answer: c

Detailed Solution: Non-repudiation ensures that once a message is signed with the signer's private key, the signer cannot deny having signed it, because anyone can verify the signature with the corresponding public key.

Thus, the correct option is (c).

QUESTION 7:

Which of the following statements is **false** regarding keyed vs unkeyed hash functions?

a. An unkeyed hash function can be used to verify data integrity when the hash value is obtained from a trusted source.
b. A keyed hash function requires a secret key as part of its computation.
c. An unkeyed hash function inherently provides authenticity.
d. HMAC can be used to provide both integrity and a degree of authentication.

Correct Answer: c

Detailed Solution: Unkeyed hash functions like MD5/SHA-256 provide integrity but not authenticity, since anyone can compute the hash without needing a secret key.

Thus, the correct (false) option is (c).

QUESTION 8:

In IPSec, which mode encrypts/protects only the payload (transport layer data) while keeping the original IP header intact?

a. Tunnel mode
b. Transport mode
c. Replay mode
d. Confidential mode
e. None of these

Correct Answer: b

Detailed Solution: IPSec Transport mode protects only the payload (transport layer data), leaving the original IP header unencrypted/intact, whereas Tunnel mode encapsulates and protects the entire original IP packet, including its header. "Replay mode" and "Confidential mode" are not standard IPSec terms.

Thus, the correct option is (b).

QUESTION 9:

Hash digest size produced by the MD5 algorithm is _____ bits.

Correct Answer: 128

Detailed Solution: MD5 always produces a fixed-length hash digest of 128 bits, regardless of the size of the input message.

Thus, the correct answer is 128.

QUESTION 10:

The block size used by the SHA-512 hashing algorithm is _____ bits.

Correct Answer: 1024

Detailed Solution: SHA-512 processes the input message in blocks of 1024 bits, producing a 512-bit hash digest.
Thus, the correct answer is 1024.

**********END*******

Course Name: ETHICAL HACKING

Assignment- Week 1

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

Which of the following statements best describes steganography?

a. Encrypting information using public and private keys.
b. Embedding information within another cover medium.
c. Tunnelling data using HTTPS and TLS.
d. Compressing data to reduce its transmission size.
e. None of these.

Correct Answer: b

Detailed Solution: Steganography is the practice of hiding the existence of a message by embedding it within another medium such as an image, audio, video, or executable file. It is distinct from encryption (which makes data illegible but doesn't hide its existence), does not eliminate the need for secrecy in all cases, and is unrelated to data compression.
Thus, the correct option is (b).

QUESTION 2:

Which of the following are valid examples of steganography?

a. Hiding text data within an image file.
b. Hiding secret data within an audio clip.
c. Encrypting a file so only the recipient can decrypt it.
d. Hiding data within an executable file.
e. Digitally signing a document to prove authorship.
f. None of these.

Correct Answer: a, b, d

Detailed Solution: Steganography involves hiding data within cover media like images, audio, or executables. Encrypting a file (option c) is encryption, not steganography, and digitally signing a document (option e) relates to authentication/non-repudiation, not information hiding. Thus, the correct options are (a), (b), and (d).

QUESTION 3:

Which of the following is/are examples of behavioural biometrics?

a. Fingerprint
b. Signature dynamics
c. Gait
d. Iris pattern
e. Keystroke dynamics
f. Retina pattern
g. Facial structure

Correct Answer: b, c, e

Detailed Solution: Behavioural biometrics relate to patterns in human behaviour, such as signature dynamics, gait, and keystroke dynamics. Fingerprint, iris pattern, retina pattern, and facial bone structure are all physiological (physical body-based) biometrics, not behavioural. Thus, the correct options are (b), (c), and (e).

QUESTION 4:

Which biometric modality is generally considered to offer very high uniqueness and reliability for identification?

a. Voice recognition
b. Facial recognition
c. Iris scan
d. Signature dynamics
e. Gait analysis

Correct Answer: c

Detailed Solution: Iris recognition offers very high uniqueness and reliability because the iris pattern is highly distinctive for everyone. Thus, iris scanning is a highly reliable biometric modality for identification.
Thus, the correct option is (c)

QUESTION 5:

What is a Denial-of-Service (DoS) attack?

a. An attack that deletes or modifies files stored on a system.
b. An attack that prevents legitimate users from accessing a service.
c. An attack that specifically targets and destroys stored password databases.
d. None of these.

Correct Answer: b

Detailed Solution: A Denial-of-Service attack aims to make a service or system inaccessible to its legitimate users, typically by overwhelming its resources, rather than directly deleting files or targeting password databases.

Thus, the correct option is (b).

QUESTION 6:

How does a Smurf DoS attack typically work?

a. It sends oversized IP packets to crash the target host.
b. It sends forged ICMP Echo requests to a network's broadcast address with the victim's spoofed source IP, causing many hosts to flood the victim with replies.
c. It exploits buffer overflow vulnerability in web server software.
d. It uses SQL injections to compromise a backend database.
e. None of these.

Correct Answer: b

Detailed Solution: In a Smurf attack, the attacker sends ICMP Echo requests to a network's broadcast address with the source IP spoofed to the victim's address. All hosts on that network then send Echo replies to the victim, overwhelming it with traffic. Oversized packets describe a Ping of Death attack, not a Smurf attack.

Thus, the correct option is (b).

QUESTION 7:

Which of the following attacks exploits the TCP three-way handshake by leaving connections in a half-open state?

a. Ping of Death attack
b. SYN flooding attack
c. Smurf attack
d. DNS spoofing attack

Correct Answer: b

Detailed Solution: SYN flooding exploits the TCP handshake by sending numerous SYN requests without completing the handshake (never sending the final ACK), leaving many half-open connections that consume server resources and prevent legitimate connections.

Thus, the correct option is (b).

QUESTION 8:

What does PGP (Pretty Good Privacy) primarily provide for secure email communication?

a. Authentication of the sender
b. Confidentiality of the message content
c. Guaranteed message availability
d. Protection against email spam filtering

Correct Answer: a, b

Detailed Solution: PGP provides authentication and confidentiality using a combination of hashing and encryption (both symmetric and asymmetric). It does not guarantee message availability, guaranteed delivery, or spam protection.

Thus, the correct options are (a) and (b).

QUESTION 9:

What is the primary purpose of the Domain Name System (DNS)?

a. To provide end-to-end encryption for email communication.
b. To translate human-readable domain names into IP addresses.
c. To compress and fragment large network messages.
d. To hide secret data inside cover media files.
e. None of these.

Correct Answer: b

Detailed Solution: DNS's core function is to resolve human-readable domain names (such as www.example.com) into their corresponding numeric IP addresses, allowing users to access resources without memorizing IP addresses.

Thus, the correct option is (b).

QUESTION 10:

Consider a grayscale image of size 1500 x 1200, where each pixel is stored using 8 bits. Using LSB steganography (1 bit hidden per pixel), how many bytes of information can be hidden in this image?

Correct Answer: 225000

Detailed Solution: Total pixels = 1500 x 1200 = 1,800,000. Since each pixel allows hiding 1-bit, total hidden bits = 1,800,000 bits. Converting to bytes: 1,800,000 / 8 = 225,000 bytes.
Thus, the correct answer is 225000.

**********END*******

NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 9

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

Which of the following statement(s) is/are true for sniffing?

a. It is a process of analyzing network activity by capturing network traffic.
b. It is a process of finding vulnerabilities in a network.
c. It is a process used for user enumeration.
d. It may require the NIC to operate in promiscuous mode to capture frames not specifically addressed to the host.
e. None of these.

Correct Answer: a, d

Detailed Solution: Sniffing is the process of analyzing network activity by capturing traffic. A NIC can be set to promiscuous mode to capture frames not specifically addressed to the host. It is not used to find vulnerabilities or enumerate users, which are separate techniques.

Thus, the correct options are (a) and (d).

QUESTION 2:

Which of the following is/are **not** a feature of Wireshark?

a. Capturing and analyzing network packets.
b. Generating statistical reports on captured traffic.
c. Manipulating and modifying live network traffic.
d. Displaying packet details with GUI support.
e. Carrying out SQL injection attacks.
f. Filtering captured packets by protocol.

Correct Answer: c, e

Detailed Solution: Wireshark can capture, analyze, filter, and generate statistical reports on traffic with GUI support. It cannot manipulate live traffic or perform SQL injection attacks.
Thus, the correct options are (c) and (e).

QUESTION 3:

Which of the following protocols are vulnerable to sniffing attacks?

a. HTTP
b. FTP
c. Telnet
d. HTTPS
e. SSL
f. SSH

Correct Answer: a, b, c

Detailed Solution: HTTP, FTP, and Telnet transmit data in plaintext, making them vulnerable to sniffing. HTTPS, SSL, and SSH encrypt data in transit, protecting it from being read even if intercepted.
Thus, the correct options are (a), (b), and (c).

QUESTION 4:

Which of the following feature(s) is/are **not** present in the Ettercap tool?

a. IP-based and MAC-based filtering.
b. Character injection into live connections.
c. Packet filtering and dropping.
d. SQL injection automation.
e. Password cracking via dictionary attack.

Correct Answer: d, e

Detailed Solution: Ettercap supports IP/MAC-based filtering, character injection into active connections, and packet filtering/dropping. It does not automate SQL injection or perform dictionary-based password cracking.

Thus, the correct options are (d) and (e).

QUESTION 5:

Which of the following is **not** a human-based social engineering attack?

a. Impersonation
b. Shoulder surfing
c. Piggybacking/tailgating
d. Phishing email

Correct Answer: d

Detailed Solution: Impersonation, shoulder surfing, and piggybacking/tailgating all involve direct human interaction or physical presence, so they are human-based social engineering. Phishing is a computer-based social engineering attack, carried out through electronic communication rather than direct human contact.

Thus, the correct option is (d).

QUESTION 6:

A DoS attack that exploits the TCP three-way handshake by leaving connections incomplete is called:

a. SYN Flooding
b. ICMP Flood
c. Ping of Death
d. UDP Flood

Correct Answer: a

Detailed Solution: SYN Flooding exploits the TCP handshake by sending repeated SYN requests without completing the final ACK step, leaving many half-open connections that exhaust the server's connection queue.

Thus, the correct option is (a).

QUESTION 7:

Which tool is specifically known for performing DoS attacks by sending partial HTTP requests and never completing them?

a. Hydra
b. Wireshark
c. Slowloris
d. Crunch

Correct Answer: c

Detailed Solution: Slowloris opens many connections to a web server and sends partial HTTP requests, keeping them open indefinitely to exhaust the server's available connections and cause a denial of service.

Thus, the correct option is (c).

QUESTION 8:

Which mode allows a network interface card (NIC) to capture frames that are not specifically addressed to the host?

a. Monitor mode
b. Transparent mode
c. Promiscuous mode
d. Bridge mode

Correct Answer: c

Detailed Solution: Promiscuous mode allows the NIC to capture frames that are not specifically addressed to its own MAC address.

Thus, the correct option is (c).

QUESTION 9:

Which of the following is/are examples of computer-based social engineering attacks?

a. Phishing emails
b. Pop-up window scams
c. Shoulder surfing
d. Chain letter emails
e. Tailgating

Correct Answer: a, b, d

Detailed Solution: Phishing emails, pop-up window scams, and chain letter emails are delivered through computer/electronic means, classifying them as computer-based social engineering. Shoulder surfing and tailgating require physical presence, making them human-based social engineering attacks.

Thus, the correct options are (a), (b), and (d).

QUESTION 10:

What is the primary purpose of ARP spoofing in the context of sniffing attacks?

a. To increase the bandwidth available to the attacker.
b. To redirect traffic between two hosts through the attacker's machine for interception.
c. To encrypt network traffic for secure transmission.
d. To permanently disable a target host's network interface.

Correct Answer: b

Detailed Solution: ARP spoofing associates the attacker's MAC address with a legitimate host's IP address, redirecting traffic intended for that host through the attacker's machine and enabling interception (man-in-the-middle), often used to facilitate sniffing on switched networks.

Thus, the correct option is (b).

**********END*******

NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 10

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

Which of the following are examples of hardware-based attacks?

a. Physical probing
b. SQL injection
c. Cross-site scripting
d. Electromagnetic emission analysis
e. Phishing

Correct Answer: a, d

Detailed Solution: Physical probing and electromagnetic emission analysis both require access to or measurement of the physical hardware running a computation. SQL injection, cross-site scripting, and phishing are software/application-level or social engineering attacks unrelated to hardware access.
Thus, the correct options are (a) and (d).

QUESTION 2:

Which of the following statement(s) is/are **true** regarding side-channel attacks?

a. They exploit weaknesses in the implementation of an algorithm, not the algorithm itself.
b. They may require physical access to (or close proximity to) the target device, depending on the side channel being exploited.
c. They rely solely on analyzing input/output pairs of the algorithm.
d. They can exploit information such as timing, power consumption, or electromagnetic emissions.
e. They exploit mathematical weaknesses in the cryptographic algorithm's design.

Correct Answer: a, b, d

Detailed Solution: Side-channel attacks exploit weaknesses in how an algorithm is implemented (hardware or software), rather than flaws in the underlying algorithm's mathematical design. Depending on the side channel being exploited, they may use information such as timing, power consumption, or electromagnetic emissions and may require physical access or close proximity to the target device. They do not rely solely on input/output analysis, which is characteristic of black-box analysis.
Thus, the correct options are (a), (b), and (d).

QUESTION 3:

For modular exponentiation of x^{22} using the square-and-multiply method, how many squaring and multiplication operations are required, respectively?

a. 4 and 2
b. 3 and 2
c. 4 and 3
d. 5 and 2
e. 3 and 3

Correct Answer: a

Detailed Solution: The binary representation of 22 is 10110. Number of squaring's = total bits - 1 = 5 - 1 = 4. Number of multiplications = (number of 1's) - 1 = 3 - 1 = 2. Hence, 4 squaring's and 2 multiplications are required.
Thus, the correct option is (a).

QUESTION 4:

Which of the following statement(s) is/are **true** regarding Differential Power Analysis (DPA) and Simple Power Analysis (SPA)?

a. DPA requires only a single power trace measurement.
b. DPA requires multiple power trace measurements combined with statistical analysis.
c. DPA uses statistical analysis of multiple traces to reveal information that may not be apparent from individual traces.
d. DPA is generally less effective than SPA.
e. SPA relies on directly observing patterns in a single or few traces.

Correct Answer: b, c, e

Detailed Solution: DPA uses multiple power measurements combined with statistical analysis to identify correlations between power consumption and sensitive data. In contrast, SPA relies on directly observing distinguishable patterns in a single or small number of traces. DPA is therefore useful for revealing leakage that may not be apparent from individual traces.
Thus, the correct options are (b), (c), and (e).

QUESTION 5:

Which property of a PUF refers to the requirement that, given a PUF and an input (challenge) x, its corresponding output (response) y = PUF(x) can be computed efficiently?

a. Unclonability
b. One-wayness
c. Evaluability
d. Unpredictability
e. Tamper-evidence

Correct Answer: c

Detailed Solution: Evaluability refers to the property that computing the response y = PUF(x) for a given challenge x should be computationally easy/efficient. Unclonability refers to the difficulty of constructing a different device that mimics the same challenge-response behaviour, and one-wayness refers to the difficulty of finding x given only y.
Thus, the correct option is (c).

QUESTION 6:

_____ is the full form of the acronym PUF used in hardware security.

a. Physically Unique Function
b. Physically Unclonable Function
c. Protected Unclonable Feature
d. Physically Untraceable Function

Correct Answer: b

Detailed Solution: PUF stands for **Physically Unclonable Function**, a hardware security primitive that exploits inherent manufacturing variations in a device to generate unique, device-specific responses.

Thus, the correct option is (b).

QUESTION 7:

What is a hardware Trojan?

a. A malicious software virus that specifically targets firmware update files.
b. A malicious, intentional modification to a chip's circuitry that activates under specific trigger conditions.
c. A testing tool used to validate hardware functionality before shipping.
d. A feature designed to make hardware run faster under heavy load.

Correct Answer: b

Detailed Solution: A hardware Trojan is a malicious modification embedded within a chip's circuitry, remaining dormant until a specific triggering condition is met, at which point it activates an unintended, harmful operation (the "payload").
Thus, the correct option is (b).

QUESTION 8:

Which of the following statement(s) is/are **true** regarding hardware Trojans?

a. They typically incur small hardware overhead, making them difficult to detect.
b. They are generally easy to detect using a single, universal detection method.
c. Detecting hardware Trojans often introduces additional design, testing, or runtime overhead.
d. Hardware Trojans are exclusively inserted through software-level modifications.

Correct Answer: a, c

Detailed Solution: Hardware Trojans typically add minimal overhead to remain stealthy, and no single detection method can reliably catch all Trojan variants, with detection efforts often adding their own overhead. No universal, easy detection method exists, and Trojans are inserted at the hardware (circuit) level, not through software modifications.
Thus, the correct options are (a) and (c).

QUESTION 9:

Which of the following hardware attack(s) are generally considered invasive in nature?

a. Black-box testing
b. Physical probing
c. Side-channel power analysis
d. Timing analysis

Correct Answer: b

Detailed Solution: Physical probing and reverse engineering that involves decapping or delayering a chip requires direct physical alteration of the device, making them invasive. Black-box testing, side-channel power analysis, and timing analysis are typically non-invasive, relying on external measurements or input/output observations rather than physically opening the chip.
Thus, the correct option is (b).

QUESTION 10:

Which of the following software-level technique(s) can help mitigate timing-based side-channel attacks?

a. Introducing redundant/dummy computations to equalize execution time across branches.
b. Masking sensitive intermediate data values during computation.
c. Deliberately increasing overall program complexity without addressing timing variance.
d. Ensuring constant-time implementations for security-critical operations.

Correct Answer: a, d

Detailed Solution: Introducing redundant or dummy computations to equalize execution time across different execution paths and using constant-time implementations for security-critical operations can help mitigate timing-based side-channel attacks. Simply increasing program complexity without addressing timing variations does not prevent timing leakage. Masking sensitive intermediate values is primarily used to mitigate other forms of side-channel leakage and does not, by itself, eliminate timing leakage.
Thus, the correct options are (a) and (d).

**********END*******

NPTEL Online Certification Courses

Indian Institute of Technology Kharagpur

Course Name: ETHICAL HACKING

Assignment- Week 11

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

Which of the following Metasploit modules is used to take advantage of a known vulnerability on a target system?

a. Payload
b. Exploit
c. Encoder
d. Auxiliary

Correct Answer: b

Detailed Solution: The exploit module is specifically designed to take advantage of a vulnerability in a target system or application. The payload establishes a communication channel after exploitation, the encoder obfuscates payloads to evade detection, and the auxiliary module performs scanning or brute-force tasks.
Thus, the correct option is (b).

QUESTION 2:

Which command is used to launch the Metasploit Framework console?

a. msfvenom
b. msfconsole
c. metasploit-cli
d. msf-start

Correct Answer: b

Detailed Solution:

The “msfcnsole” command is used to launch the Metasploit Framework.
Thus, the correct option is (b).

QUESTION 3:

Which Metasploit command is used to check which target operating systems are compatible with a selected exploit?

a. show targets
b. set targets
c. check compatibility
d. show exploits
e. show payloads

Correct Answer: a

Detailed Solution: The "show targets" command displays the list of compatible target operating systems for the currently selected exploit module, helping the user select the correct target environment.
Thus, the correct option is (a).

QUESTION 4:

Which Metasploit option is used to specify the target's IP address (the remote host to be attacked)?

a. set LHOST
b. set LPORT
c. set RHOST
d. set RPORT

Correct Answer: c

Detailed Solution: RHOST is used to set the remote host (target) IP address, while LHOST sets the attacker's (local) IP, and RPORT/LPORT set the respective port numbers.
Thus, the correct option is (c).

QUESTION 5:

Which command in Metasploit's Meterpreter shell is used to retrieve stored user account password hashes from the target system?

a. Getuid
b. Getsystem
c. Hashdump
d. Sysinfo
e. ps

Correct Answer: c

Detailed Solution: The hashdump command retrieves stored password hashes from the target system's SAM database (on Windows) or equivalent, which can then be used for offline password cracking. getuid shows the current user ID, getsystem attempts privilege escalation, sysinfo shows target system details, and ps lists running processes.
Thus, the correct option is (c).

QUESTION 6:

Which tool is specifically designed to perform brute-force discovery of hidden files and directories on a web server?

a. SQLMAP
b. Dirb
c. Hydra
d. Crunch
e. Hashcat

Correct Answer: b

Detailed Solution: Dirb performs brute-force discovery of existing and hidden pages or directories on a web server using a wordlist. SQLMap automates SQL injection attacks, Hydra and Crunch are password-cracking and wordlist-generating tools, respectively; and Hashcat cracks password hashes.

Thus, the correct option is (b).

QUESTION 7:

If a web page is vulnerable to error-based SQL injection, what is the expected behavior upon incorrect/malicious user input?

a. It will display a database error message revealing information about the query structure.
b. It will silently return no output at all.
c. It will redirect the user to a login page automatically.
d. It will crash the entire web server permanently.

Correct Answer: a

Detailed Solution: In error-based SQL injections, malformed or malicious input causes the application to generate a visible database error message, which can leak useful information about the underlying query structure and database schema.

Thus, the correct option is (a).

QUESTION 8:

Which SQLMAP option is used to list all database names available on the target system?

a. --tables
b. --dbs
c. --dump
d. --current-db
e. --passwords

Correct Answer: b

Detailed Solution: The --dbs option lists all available database names on the target. --tables lists tables within a chosen database, --dump extracts data from specified tables, --current-db shows the currently active database, and --passwords retrieves password hashes.

Thus, the correct option is (b).

QUESTION 9:

Which of the following is/are recognized types of Cross-Site Scripting (XSS) attacks?

a. Stored XSS
b. Reflected XSS
c. DOM-based XSS
d. SQL-based XSS
e. Cookie-Injection XSS

Correct Answer: a, b, c

Detailed Solution: Stored, Reflected, and DOM-based XSS are the three classical, recognized categories of Cross-Site Scripting attacks. "SQL-based XSS" and "Cookie-Injection XSS" are not standard or recognized XSS classifications.

Thus, the correct options are (a), (b), and (c).

QUESTION 10:

Consider the following simplified query used by a login form:

SELECT * FROM users WHERE username = 'INPUT1' AND password = 'INPUT2'

Which of the following input(s) for the username field, if unsanitized, would represent a classic SQL injection attempt to bypass authentication?

a. admin
b. admin' OR '1'='1
c. admin123
d. 'OR 1=1 –
e. guest_user

Correct Answer: b, d

Detailed Solution: Both "admin' OR '1'='1" and "' OR 1=1 --" are classic SQL injection payloads that manipulate the query's logic to always evaluate as true, potentially bypassing authentication. The other options are normal, non-malicious input values.

Thus, the correct options are (b) and (d).

**********END*******

Course Name: ETHICAL HACKING

Assignment- Week 12

TYPE OF QUESTION: MCQ/MSQ/SA

Number of questions: 10 **Total mark: 10 x 1 = 10**

QUESTION 1:

In an ICMP Echo sweep, if the scanner receives an ICMP Type 0 packet in response to an ICMP Type 8 request, what does this indicate?

a. The target host is alive/up
b. The target host is down
c. The target port is filtered
d. The target host does not support ICMP

Correct Answer: a

Detailed Solution: ICMP Type 0 is an Echo Reply. Receiving this in response to an Echo Request (Type 8) confirms that the target host is alive and responding.
Thus, the correct option is (a).

QUESTION 2:

Which of the following NMAP option(s) can be used to perform a TCP-based sweep for host discovery?

a. -PE
b. -PS
c. -PA
d. -PU
e. -PM

Correct Answer: b, c

Detailed Solution: -PS (TCP SYN ping) and -PA (TCP ACK ping) are used for TCP-based host discovery sweeps. -PE is ICMP Echo sweep, -PU is UDP sweep, and -PM is ICMP Address Mask (non-echo) sweep.
Thus, the correct options are (b) and (c).

QUESTION 3:

Which of the following are automatically performed when using the NMAP -sn option?

a. ICMP Echo sweep
b. TCP sweep
c. UDP sweep
d. All of these

Correct Answer: a, b

Detailed Solution: The -sn option performs host discovery using ICMP Echo and TCP sweep techniques together, but does not include UDP sweep as part of its default behavior.
Thus, the correct options are (a) and (b).

QUESTION 4:

Which NMAP option treats all hosts as online, effectively skipping the host discovery phase?

a. -sL
b. -sP
c. -PO
d. -sU
e. -Pn

Correct Answer: e

Detailed Solution: The -Pn option instructs NMAP to skip host discovery entirely and treat all specified hosts as online, proceeding directly to the scanning phase. -sL only lists targets, -sP performs a ping-only scan, -PO is IP protocol ping, and -sU performs a UDP scan.
Thus, the correct option is (e).

QUESTION 5:

Consider the following statements:

(i) -sn performs host discovery only, without any port scanning.

(ii) -Pn skips host discovery entirely and proceeds directly to port scanning.

a. Only (i) is true
b. Only (ii) is true
c. Both (i) and (ii) are true
d. Both (i) and (ii) are false

Correct Answer: c

Detailed Solution: -sn performs host discovery only, skipping port scanning entirely, while -Pn does the opposite — skipping host discovery and assuming all hosts are online, which is useful when a target blocks ICMP-based discovery but is still reachable for port scanning. These two options serve distinct, near-opposite purposes, not identical ones, and -sn does not perform a port scan afterwards.
Thus, the correct option is (c).

QUESTION 6:

Which of the following statement(s) is/are **true** regarding NMAP's -F (fast scan) option?

a. It scans the top 100 most common ports.
b. It scans all 65535 ports.
c. It is faster than a default scan because it checks fewer ports.
d. It is equivalent to using --top-ports 1000

Correct Answer: a, c

Detailed Solution: The -F (fast) option scans only the top 100 most common ports, making it quicker than the default scan (which covers the top 1000 ports). It does not scan all 65535 ports, and it is not equivalent to --top-ports 1000, since it covers only 100 ports, not 1000.

Thus, the correct options are (a) and (c).

QUESTION 7:

Which NMAP option is specifically used to conduct a UDP port scan?

a. -sT
b. -sS
c. -sU
d. -sA
e. -sN

Correct Answer: c

Detailed Solution: The -sU option performs a UDP scan. -sT is TCP Connect scan, -sS is TCP SYN scan, -sA is TCP ACK scan, and -sN is NULL scan (all TCP-based, not UDP).

Thus, the correct option is (c).

QUESTION 8:

Which scanning technique completes the full TCP three-way handshake with the target port to determine its state?

a. TCP SYN scan
b. TCP Connect scan
c. FIN scan
d. NULL scan
e. Xmas scan

Correct Answer: b

Detailed Solution: TCP Connect scan (-sT) completes the entire three-way handshake (SYN, SYN-ACK, ACK) with the target port. TCP SYN scan is a "half-open" scan that doesn't complete the handshake, while FIN, NULL, and Xmas scans use unusual flag combinations and don't involve a standard handshake at all.

Thus, the correct option is (b).

QUESTION 9:

How many ports will be scanned using the NMAP command "nmap --top-ports 20 target_ip"?

Correct Answer: 20

Detailed Solution: The --top-ports option scans the N most commonly used ports specified. Here, N = 20, so exactly 20 of the most common ports will be scanned.

QUESTION 10:

How many total IP addresses will be scanned when executing the command nmap -sL 10.10.5.100-115?

Correct Answer: 16

Detailed Solution: The command scans all IP addresses from 10.10.5.100 to 10.10.5.115, inclusive.
Thus, the correct answer is 16.

**********END*******